

OIDC Setup Checklist for nokit CS2 RCON Panel

Quick reference for setting up OIDC authentication with Authelia + Ildap.

Prerequisites

- [] Ildap running and accessible
- [] Authelia running and accessible
- [] Redis (for Authelia sessions) - optional but recommended
- [] SSL certificates (for HTTPS) - required for production

Step 1: Create Groups in Ildap

→ See detailed guide: [lldap-groups-setup.md](#) (./lldap-groups-setup.md)

- [] Access Ildap web UI (<http://localhost:17170> or your domain)
- [] Create group: `cs2-rcon-viewer`
- [] Create group: `cs2-rcon-operator`
- [] Create group: `cs2-rcon-admin`
- [] Create group: `cs2-rcon-superadmin`
- [] Assign users to appropriate group(s)
- [] Verify group membership shows in Ildap UI

Critical: Group names must match **exactly** (case-sensitive).

Step 2: Configure Authelia

→ See example config: [authelia-config-example.yml](#) (./authelia-config-example.yml)

A. Generate Required Secrets

```
# Session secret
openssl rand -base64 64

# Encryption key
openssl rand -base64 64

# HMAC secret
openssl rand -base64 64

# OIDC RSA key
openssl genrsa -out /path/to/authelia/secrets/oidc_key.pem 4096

# Client secret (plaintext - save this for step 2C)
openssl rand -base64 64

# Hash the client secret for Authelia
docker run --rm authelia/authelia:latest authelia crypto hash generate pbkdf2 --password 'YOUR_PLAINTEXT_CLIENT_SECRET_FROM_ABOVE'
```

B. Edit configuration.yml

- [] Set `authentication_backend.ldap.address` to your ldap host
- [] Set `authentication_backend.ldap.base_dn` (e.g., `dc=example,dc=com`)
- [] Set `authentication_backend.ldap.user` admin DN
- [] Set `authentication_backend.ldap.password` (ldap admin password)
- [] Verify `groups_filter: '(member={dn})'` and `group_name_attribute: 'cn'`
- [] Update `session.cookies[0].domain` to your root domain
- [] Set `session.secret`, `storage.encryption_key`, `oidc.hmac_secret`
- [] Load `oidc.issuer_private_key` from the RSA key file
- [] Add `access_control` rule for `rcon.example.com` with all 4 groups
- [] Configure OIDC client (see step 2C below)

C. Configure OIDC Client for nokit

In `identity_providers.oidc.clients`, add:

```
clients:
- client_id: 'cs2rcon'
  client_name: 'CS2 RCON Panel'
  client_secret: '$pbkdf2-sha512$310000$...' # Hashed secret from step 2A
  public: false
  authorization_policy: 'two_factor' # or 'one_factor'
  redirect_uris:
  - 'https://rcon.example.com/api/auth/callback' # YOUR panel URL
  scopes:
  - 'openid'
  - 'profile'
  - 'email'
  - 'groups' # REQUIRED for group-based permissions
  grant_types:
  - 'authorization_code'
  - 'refresh_token'
  response_types:
  - 'code'
  token_endpoint_auth_method: 'client_secret_basic'
```

Save the plaintext `client_secret` — you'll need it for step 3.

- [] Client configured in Authelia
- [] Redirect URI matches your panel's public URL + `/api/auth/callback`
- [] `groups` scope included
- [] Restart Authelia

Step 3: Configure nokit Panel

→ See example: `docker-compose.oidc-example.yml` (`./docker-compose.oidc-example.yml`)

Environment Variables

In your `.env` file or `docker-compose.yml` :

```
# Authentication mode
AUTH_MODE=oidc

# Authelia issuer URL (must be reachable from the panel container)
OIDC_ISSUER_URL=https://auth.example.com

# OAuth2 client credentials (must match Authelia)
OIDC_CLIENT_ID=cs2rcon
OIDC_CLIENT_SECRET=your-plaintext-secret-from-step-2A # NOT the hashed one

# Public callback URL (must match Authelia's redirect_uris)
OIDC_REDIRECT_URL=https://rcon.example.com/api/auth/callback

# Optional: Override scopes (defaults to "openid profile email groups")
# OIDC_SCOPES=openid profile email groups

# Optional: Post-logout redirect
# OIDC_POST_LOGOUT_REDIRECT_URL=https://rcon.example.com/login

# Only for local HTTP testing (NOT for production)
# AUTH_COOKIE_INSECURE=1
```

Critical checks:

- [] `OIDC_ISSUER_URL` is reachable from the panel container (use Docker network names if in same stack)
- [] `OIDC_CLIENT_ID` matches Authelia's `client_id`
- [] `OIDC_CLIENT_SECRET` is the **plaintext** secret (Authelia stores the hash)
- [] `OIDC_REDIRECT_URL` exactly matches one of Authelia's `redirect_uris`
- [] If behind a reverse proxy, ensure `X-Forwarded-*` headers are passed correctly

Docker Compose Networking

If Authelia is in a different Docker Compose stack:

```
services:
  defuse:
    networks:
      - cs2
      - authelia # Add this

networks:
  authelia:
    external: true # Create with: docker network create authelia
```

- [] Panel container can reach Authelia
- [] Panel container can reach ldap (if needed for debugging)
- [] Restart the panel container

Step 4: Test the Setup

4.1 Verify Authelia Discovery

```
curl https://auth.example.com/.well-known/openid-configuration
```

Should return JSON with `authorization_endpoint`, `token_endpoint`, `userinfo_endpoint`, etc.

- [] OIDC discovery endpoint works

4.2 Test Login Flow

1. Open the panel: `https://rcon.example.com`
2. You should see a **“Sign in with SSO”** button
3. Click it
4. Redirect to Authelia login page
5. Log in with a user that’s in one of the `cs2-rcon-*` groups
6. Complete 2FA if enabled
7. Redirect back to panel
8. You should be logged in and see the dashboard

- [] SSO button appears on login page
- [] Redirect to Authelia works
- [] Login successful
- [] User redirected back to panel
- [] Dashboard loads

4.3 Verify Permissions

Open browser DevTools → Network tab → find `GET /api/me` response:

```
{
  "username": "alice",
  "email": "alice@example.com",
  "groups": ["cs2-rcon-admin", "lldap_admin"],
  "roles": ["admin"],
  "isLocal": false,
  "permissions": {
    "view_dashboard": true,
    "view_players": true,
    "send_console_command": true,
    "add_server": true,
    "view_audit": true,
    "delete_server": false, // Only superadmin can delete
    ...
  }
}
```

- [] `groups` field shows ldap groups
- [] `roles` field shows correct role (viewer/operator/admin/superadmin)
- [] `permissions` match the expected role
- [] UI elements (delete buttons, etc.) appear/hidden based on permissions

4.4 Test Permission Enforcement

Try as a **viewer**:

- [] Can see dashboard
- [] **Cannot** send console commands (no input box or 403 error)
- [] **Cannot** see delete buttons

Try as an **admin**:

- [] Can add servers
- [] Can view audit log
- [] **Cannot** delete servers (button hidden or 403)

Try as a **superadmin**:

- [] Can delete servers
- [] Can delete configs

4.5 Test Logout

1. Click username in header → Logout
2. Should redirect to Authelia logout
3. Then redirect back to panel login page
4. User is logged out
 - [] Logout redirects to Authelia
 - [] Redirects back to panel
 - [] Session cleared (accessing protected pages returns 401)

Common Issues

“Failed to fetch OIDC configuration”

Cause: `OIDC_ISSUER_URL` is unreachable from the panel container.

Fix:

- Check Docker networking
- Use `http://authelia:9091` if Authelia is in the same Docker network
- Use public domain if Authelia is external
- Check Authelia is running: `docker logs authelia`

“Invalid redirect_uri”

Cause: `OIDC_REDIRECT_URL` doesn't match Authelia's `redirect_uris`.

Fix:

- Ensure exact match: `https://rcon.example.com/api/auth/callback`
- Check for trailing slashes, http vs https, port numbers
- Update Authelia config and restart

“User gets 403 Access Denied after login”

Cause: User is not in any `cs2-rcon-*` group.

Fix:

- Check lldap: User → “Member of groups”
- Add user to at least `cs2-rcon-viewer`

“User logs in but has no permissions”

Cause: Groups not being passed in OIDC token.

Fix:

- Check Authelia OIDC client has `scopes: ['groups']`
- Check panel env has `OIDC_SCOPES` includes `groups` (or leave unset for default)
- Check Authelia LDAP config `groups_filter` and `group_name_attribute`
- Check `/api/me` response for `groups` field
- Log out and log back in to refresh token

“Invalid client_secret”

Cause: Panel is using hashed secret instead of plaintext, or secrets don't match.

Fix:

- Panel (`OIDC_CLIENT_SECRET`) = **plaintext** secret
- Authelia (`client_secret`) = **pbkdf2 hash** of the same secret
- Generate hash: `authelia crypto hash generate pbkdf2 --password 'plaintext'`

Security Checklist

Production deployment:

- ☐ All secrets are randomly generated (64+ characters)
- ☐ HTTPS enabled with valid certificates
- ☐ `AUTH_COOKIE_INSECURE` NOT set (or set to `0`)
- ☐ Authelia using PostgreSQL/MySQL (not SQLite)
- ☐ Authelia using Redis for sessions (not filesystem)
- ☐ SMTP configured for password resets and 2FA
- ☐ Two-factor authentication enforced (Authelia `authorization_policy: 'two_factor'`)
- ☐ Authelia `regulation` enabled (brute-force protection)
- ☐ Network security: Authelia/Ildap not exposed to public internet (only panel needs public access)
- ☐ Regular backups of Authelia database and Ildap data

Quick Reference: The Three Places

What	Where	Example
1. Groups	Ildap UI	Create <code>cs2-rcon-viewer</code> , <code>cs2-rcon-operator</code> , <code>cs2-rcon-admin</code> , <code>cs2-rcon-super-admin</code>
2. Access Control	Authelia <code>configuration.yml</code>	<code>access_control.rules[0].subject: ['group:cs2-rcon-viewer', ...]</code>
3. OIDC Client	Authelia <code>configuration.yml</code>	<code>identity_providers.oidc.clients[0].scopes: ['groups'] + redirect_uris</code>
4. Panel Env	<code>nokit .env</code> or <code>docker-compose</code>	<code>OIDC_ISSUER_URL</code> , <code>OIDC_CLIENT_ID</code> , <code>OIDC_CLIENT_SECRET</code> , <code>OIDC_REDIRECT_URL</code>

Support

If you encounter issues:

1. Check panel logs: `docker logs defuse`
2. Check Authelia logs: `docker logs authelia`
3. Check Ildap logs: `docker logs ldap`
4. Open browser DevTools → Network tab → check API responses
5. Verify group names match exactly (case-sensitive)

For more help, see the [GitHub Issues](https://github.com/wiblash-s/nokit/issues) (<https://github.com/wiblash-s/nokit/issues>).